

Relazione di conformità

Operatore Esempio S.r.l. · Soggetto essenziale · situazione al 06/10/2026

Decreto legislativo 4 settembre 2024, n. 138 — atto nazionale di recepimento della direttiva; questo modulo non ne valuta ancora i requisiti

Strumento di autovalutazione ITORO — il documento non costituisce un audit né un parere legale.

Sintesi per la direzione

STATUS DEL SOGGETTO

Soggetto essenziale

direttiva NIS 2 articolo 3, paragrafo 1, lettera c),

(fornitore di reti pubbliche di comunicazione elettronica o di servizi di comunicazione elettronica accessibili al pubblico che è almeno una media impresa)

GRADO DI PREPARAZIONE

59%

Maturità 2.4 con livello obiettivo 4

OBBLIGHI FORMALI

8/16

3 non adempiuti, 5 in corso

Prossime scadenze di legge

17/10/2027

(tra 376 giorni)

— Primo riesame della direttiva da parte della Commissione

Lacune maggiori

1. Igiene informatica e formazione — maturità 2.0 rispetto all'obiettivo 4, priorità critico

2. 7. Strategie e procedure per valutare l'efficacia delle misure di gestione dei rischi di cibersicurezza [articolo 21, paragrafo 2, lettera f), della direttiva (UE) 2022/2555] — maturità 2.0 rispetto all'obiettivo 4, priorità critico

3. 9. Crittografia [articolo 21, paragrafo 2, lettera h), della direttiva (UE) 2022/2555] — maturità 2.0 rispetto all'obiettivo 4, priorità critico

4. 2. Politica di gestione dei rischi [articolo 21, paragrafo 2, lettera a), della direttiva (UE) 2022/2555] — maturità 2.2 rispetto all'obiettivo 4, priorità alta

5. 4. Continuità operativa e gestione delle crisi [articolo 21, paragrafo 2, lettera c), della direttiva (UE) 2022/2555] — maturità 2.2 rispetto all'obiettivo 4, priorità alta

Le autorità acquisiscono il potere di irrogare sanzioni pecuniarie dal 17/10/2024 direttiva NIS 2 articolo 41, paragrafo 1). Da quando l'autorità nazionale può irrogare sanzioni lo stabilisce la legge di recepimento: questo modulo non la conosce. Il rischio finanziario non è quindi datato qui, mentre gli obblighi di attuazione derivano dal diritto nazionale dalla sua entrata in vigore.

Responsabilità finanziaria

Soggetto

Come si forma questo massimale — due passaggi distinti

1. Il massimale minimo è fissato dalla direttiva

Si confrontano due valori: un importo fisso in euro e una percentuale del fatturato mondiale totale annuo dell'impresa nell'esercizio precedente. Il maggiore è il limite massimo che lo Stato membro deve quantomeno prevedere. Il diritto nazionale può innalzarlo.

direttiva NIS 2 articolo 34, paragrafo 4 e 5
2. L'importo entro il massimale è stabilito dall'autorità nazionale

La sanzione deve essere effettiva, proporzionata e dissuasiva secondo le circostanze del singolo caso. L'autorità tiene conto almeno dei criteri dell'articolo 32, paragrafo 7: gravità e durata della violazione, violazioni precedenti, danni, intenzionalità, misure correttive e cooperazione.

direttiva NIS 2 articolo 34, paragrafo 1 e 3
- Il massimale può superare più volte il fatturato annuo: è un limite massimo, non un importo atteso. Minimi nazionali, penalità di mora e modalità di determinazione sono stabiliti dalla legge dello Stato membro.

Il massimale di legge della sanzione pecuniaria è pari a **10.000.000 EUR**. Prevale l'importo fisso: 10 milioni di EUR è superiore al 2 % del fatturato.

- Variante percentuale: 480.000 EUR
- Variante in importo fisso: 10.000.000 EUR
- Minimo di legge: 0 EUR

I massimali dell'articolo 34, paragrafi 4 e 5, sono minimi («almeno»): il diritto nazionale può prevederne di più elevati. Importi in euro, senza conversione nella valuta nazionale.

Graduazione della sanzione — **direttiva NIS 2** articolo 34, paragrafo 3 e articolo 32, paragrafo 7

- Nel decidere se irrogare una sanzione amministrativa pecuniaria e nel determinarne l'importo, in ogni singolo caso si tiene debitamente conto almeno degli elementi elencati nell'articolo 32, paragrafo 7.
- Criteri dell'articolo 32, paragrafo 7, della direttiva:
- gravità della violazione e importanza delle disposizioni violate; sono in ogni caso considerate gravi: le violazioni ripetute, la mancata notifica o la mancata correzione di incidenti significativi, la mancata rimozione delle carenze in violazione di istruzioni vincolanti, l'ostruzione di audit o monitoraggio, la fornitura di informazioni false o gravemente inesatte
 - czas trwania naruszenia
 - eventuali violazioni precedenti pertinenti da parte del soggetto
 - danni materiali o immateriali causati, comprese le perdite finanziarie, l'impatto su altri servizi e il numero di utenti interessati
 - carattere doloso o colposo della violazione
 - misure adottate per prevenire o attenuare i danni
 - adesione a codici di condotta approvati o a meccanismi di certificazione
 - grado di cooperazione con le autorità competenti
- La direttiva non prevede espressamente la rinuncia alla sanzione: se e quando sia possibile lo decide il diritto nazionale.

- Gli Stati membri possono prevedere penalità di mora per costringere a cessare una violazione. L'importo è stabilito dal diritto nazionale.
- La direttiva non prevede una sanzione distinta per la violazione qualificata: è una costruzione del diritto nazionale di alcuni paesi.

Responsabile del soggetto

Atto giuridico	Base	Autorità	Massimale
Direttiva (UE) 2022/2555	direttiva NIS 2 articolo 20, paragrafo 1	Autorità competente dello Stato membro	0 EUR

- L'organo di gestione approva le misure di gestione dei rischi di cibersicurezza (articolo 20, paragrafo 1).
- L'organo di gestione sorveglia l'attuazione di tali misure (articolo 20, paragrafo 1).
- I membri dell'organo di gestione seguono una formazione regolare (articolo 20, paragrafo 2).
- Nei confronti di un soggetto essenziale l'autorità può chiedere il divieto temporaneo di esercitare funzioni dirigenziali (articolo 32, paragrafo 5, lettera b)).

Il soggetto svolge attività di comunicazione elettronica: la responsabilità della persona dirigente è regolata dal diritto nazionale

Le autorità acquisiscono il potere di irrogare sanzioni pecuniarie dal **17/10/2024** (**direttiva NIS 2** articolo 41, paragrafo 1). Da quando l'autorità nazionale può irrogare sanzioni lo stabilisce la legge di recepimento: questo modulo non la conosce. Gli obblighi di attuazione derivano dal diritto nazionale dalla sua entrata in vigore.

2.4
Rozwijany
MATURITÀ COMPLESSIVA

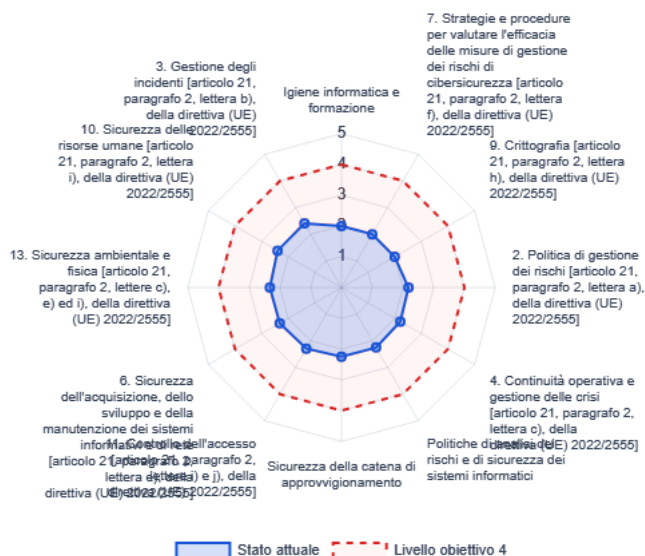
59%
Obiettivo: livello 4
GRADO DI CONFORMITÀ

1.6
al livello obiettivo
LACUNA MEDIA

212/212
100% completato
RISPOSTE

Profilo di maturità

12 aree con la lacuna maggiore su 23

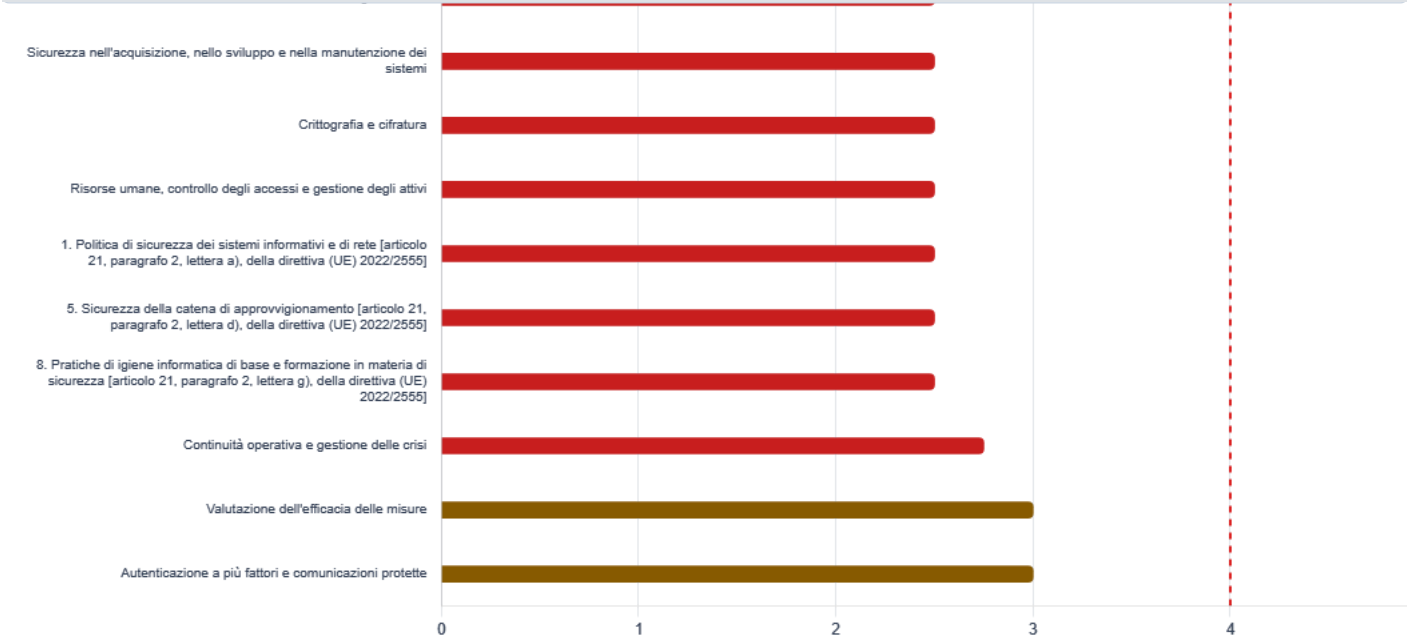


Maturità per area



Completamento per atto giuridico

Atto giuridico	Complete	Maturità
Obblighi Direttiva NIS 2 — obblighi formali	16/16	—
NIS 2 Direttiva NIS 2 — articolo 21	35/35	2.5
2024/2690 Regolamento (UE) 2024/2690	161/161	2.3



Analisi delle lacune						
Area		Attuale	Obiettivo	Lacuna	Priorità	Completamento
Igiene informatica e formazione		2.0	4	2.0	Critico	3/3
direttiva NIS 2 articolo 21, paragrafo 2, lettera g)						
direttiva NIS 2 articolo 20, paragrafo 2						
7. Strategie e procedure per valutare l'efficacia delle misure di gestione dei rischi di cibersicurezza [articolo 21, paragrafo 2, lettera f), della direttiva (UE) 2022/2555]		2.0	4	2.0	Critico	3/3
reg. 2024/2690 Allegato, sezione 7						
9. Crittografia [articolo 21, paragrafo 2, lettera h), della direttiva (UE) 2022/2555]		2.0	4	2.0	Critico	3/3
reg. 2024/2690 Allegato, sezione 9						
2. Politica di gestione dei rischi [articolo 21, paragrafo 2, lettera a), della direttiva (UE) 2022/2555]		2.2	4	1.8	Alta	11/11
reg. 2024/2690 Allegato, sezione 2						
4. Continuità operativa e gestione delle crisi [articolo 21, paragrafo 2, lettera c), della direttiva (UE) 2022/2555]		2.2	4	1.8	Alta	14/14
reg. 2024/2690 Allegato, sezione 4						
Politiche di analisi dei rischi e di sicurezza dei sistemi informatici		2.3	4	1.8	Alta	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera a)						
Sicurezza della catena di approvvigionamento		2.3	4	1.8	Alta	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera d)						
direttiva NIS 2 articolo 21, paragrafo 3						
11. Controllo dell'accesso [articolo 21, paragrafo 2, lettere i) e j), della direttiva (UE) 2022/2555]		2.3	4	1.7	Alta	21/21
reg. 2024/2690 Allegato, sezione 11						
6. Sicurezza dell'acquisizione, dello sviluppo e della manutenzione dei sistemi informativi e di rete [articolo 21, paragrafo 2, lettera e), della direttiva (UE) 2022/2555]		2.3	4	1.7	Alta	31/31
reg. 2024/2690 Allegato, sezione 6						
13. Sicurezza ambientale e fisica [articolo 21, paragrafo 2, lettere c), e) ed i), della direttiva (UE) 2022/2555]		2.3	4	1.7	Alta	9/9
reg. 2024/2690 Allegato, sezione 13						
10. Sicurezza delle risorse umane [articolo 21, paragrafo 2, lettera i), della direttiva (UE) 2022/2555]		2.4	4	1.6	Alta	10/10
reg. 2024/2690 Allegato, sezione 10						
3. Gestione degli incidenti [articolo 21, paragrafo 2, lettera b), della direttiva (UE) 2022/2555]		2.4	4	1.6	Alta	22/22
reg. 2024/2690 Allegato, sezione 3						
12. Gestione delle risorse [articolo 21, paragrafo 2, lettera i), della direttiva (UE) 2022/2555]		2.5	4	1.5	Alta	13/13
reg. 2024/2690 Allegato, sezione 12						
Gestione degli incidenti		2.5	4	1.5	Alta	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera b)						
Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione dei sistemi		2.5	4	1.5	Alta	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera e)						
Crittografia e cifratura		2.5	4	1.5	Alta	2/2
direttiva NIS 2 articolo 21, paragrafo 2, lettera h)						
Risorse umane, controllo degli accessi e gestione degli attivi		2.5	4	1.5	Alta	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera i)						
1. Politica di sicurezza dei sistemi informativi e di rete [articolo 21, paragrafo 2, lettera a), della direttiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
reg. 2024/2690 Allegato, sezione 1						
5. Sicurezza della catena di approvvigionamento [articolo 21, paragrafo 2, lettera d), della direttiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
reg. 2024/2690 Allegato, sezione 5						
8. Pratiche di igiene informatica di base e formazione in materia di sicurezza [articolo 21, paragrafo 2, lettera g), della direttiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
reg. 2024/2690 Allegato, sezione 8						
Continuità operativa e gestione delle crisi		2.8	4	1.3	Medio	4/4
direttiva NIS 2 articolo 21, paragrafo 2, lettera c)						
Valutazione dell'efficacia delle misure		3.0	4	1.0	Medio	3/3
direttiva NIS 2 articolo 21, paragrafo 2, lettera f)						

Area	Attuale	Obiettivo	Lacuna	Priorità	Completamento
Autenticazione a più fattori e comunicazioni protette	3.0	4	1.0	Medio	3/3
direttiva NIS 2 articolo 21, paragrafo 2, lettera j)					

Registro dei rischi legali — obblighi non adempiuti				
Obbligo	Base		Scadenza	Rischio sanzionatorio
Se il soggetto è fornitore di servizi DNS, registro TLD, fornitore cloud, data center, CDN, servizi gestiti, mercato online, motore di ricerca o social network, ha trasmesso i dati aggiuntivi di cui all'articolo 27, compreso l'indirizzo dello stabilimento principale nell'Unione? Dati di registrazione per l'elenco dei soggetti	direttiva NIS 2 articolo 27, paragrafo 2		—	articolo 34
Se il soggetto è un prestatore di servizi fiduciari, notifica gli incidenti significativi entro 24 ore dal momento in cui ne viene a conoscenza? Notifica degli incidenti significativi	direttiva NIS 2 articolo 23, paragrafo 4, secondo comma		24 godziny	articolo 34
Il soggetto essenziale è preparato a un audit di sicurezza svolto dall'autorità o da un organismo indipendente, a proprie spese? Prontezza alle attività di vigilanza	direttiva NIS 2 articolo 32, paragrafo 2, lettera b–c i), paragrafo 3		—	articolo 32, paragrafo 4

Calendario di legge				
Data	Evento	Base		Rimanente
16/01/2023	Entrata in vigore della direttiva NIS 2 Il ventesimo giorno successivo alla pubblicazione nella Gazzetta ufficiale.	direttiva NIS 2 articolo 45		in vigore
17/10/2024	Termine di recepimento della direttiva Entro questa data gli Stati membri dovevano adottare e pubblicare le disposizioni nazionali.	direttiva NIS 2 articolo 41, paragrafo 1		in vigore
18/10/2024	Applicazione delle disposizioni nazionali e abrogazione della NIS 1 Da questa data gli Stati applicano le disposizioni di attuazione; la direttiva (UE) 2016/1148 è abrogata.	direttiva NIS 2 articolo 41, paragrafo 1 e articolo 44		in vigore
07/11/2024	Applicazione del regolamento (UE) 2024/2690 Il regolamento di esecuzione si applica direttamente dal ventesimo giorno successivo alla pubblicazione.	reg. 2024/2690 articolo 16		in vigore
17/04/2025	Elenco dei soggetti essenziali e importanti Entro questa data gli Stati membri istituiscono l'elenco; i soggetti trasmettono alle autorità i dati di registrazione.	direttiva NIS 2 articolo 3, paragrafo 3 e 4		scaduto
17/10/2027	Primo riesame della direttiva da parte della Commissione La Commissione riesamina il funzionamento della direttiva e presenta una relazione.	direttiva NIS 2 articolo 40		376 giorni

Soglie dell'incidente significativo

Per i ruoli seguenti le soglie derivano direttamente dal regolamento (UE) 2024/2690 e si applicano dal 7 novembre 2024.

Fornitori di servizi di data center (Articolo 8)

L'insieme di soglie più severo dell'intero regolamento. Per i data center NON esiste né la soglia dei 30 minuti né quella del 5 % / 1 milione di utenti: ogni indisponibilità totale del servizio e ogni violazione dell'accesso fisico costituiscono un incidente significativo.

- **a)** Il servizio di data center è completamente indisponibile — SENZA soglia temporale.
- **b)** La disponibilità del servizio è limitata per più di 1 ora — SENZA soglia percentuale né di numero di utenti.
- **c)** Sono compromesse l'integrità, la riservatezza o l'autenticità dei dati a seguito di un'azione presumibilmente dolosa.
- **d)** È compromesso l'accesso fisico al data center gestito dal fornitore.

Criteri orizzontali (articolo 3, paragrafo 1) — basta soddisfarne uno

- **a)** Perdita finanziaria — La perdita finanziaria subita o possibile supera 500 000 EUR o il 5 % del fatturato annuo totale del soggetto nell'esercizio precedente, se inferiore.
- **b)** Fuga di segreti commerciali — L'incidente ha causato o può causare l'esfiltrazione di segreti commerciali ai sensi dell'articolo 2, punto 1, della direttiva (UE) 2016/943.
- **c)** Decesso di una persona fisica — L'incidente ha causato o può causare il decesso di una persona fisica.
- **d)** Danno considerevole alla salute — L'incidente ha causato o può causare un danno considerevole alla salute di una persona fisica.
- **e)** Accesso non autorizzato — Si è verificato un accesso riuscito, presumibilmente doloso e non autorizzato ai sistemi informatici e di rete, in grado di causare gravi perturbazioni operative.
- **f)** Incidenti ricorrenti — L'incidente soddisfa i criteri dell'articolo 4: si è verificato almeno due volte in sei mesi, gli incidenti hanno la stessa causa principale apparente e complessivamente soddisfano il criterio della perdita finanziaria di cui all'articolo 3, paragrafo 1, lettera a). Sono considerati collettivamente un unico incidente significativo.
- **g)** Criterio settoriale — L'incidente soddisfa almeno uno dei criteri settoriali stabiliti dagli articoli da 5 a 14 del regolamento.

Attività di comunicazione elettronica: le soglie sono fissate dal diritto nazionale. Il regolamento (UE) 2024/2690 non si applica ai fornitori di reti pubbliche e servizi di comunicazione elettronica. Per loro le soglie dell'incidente significativo sono fissate dal diritto nazionale (articolo 23, paragrafo 11, della direttiva): questo modulo non le conosce e quindi non indica valori.

Cronologia e progressi

Nessuna istantanea è stata ancora salvata. Un'istantanea congela lo stato attuale della valutazione con la data, così le relazioni successive mostrano i progressi.

Salva la prima istantanea